

The 100-Minute Security Hotfix

01:40:00

COMPILATION COMPLETE: 100 MINUTES



START: T+00:00:00

END: T+01:40:00

Incident INC-003: Anatomy of a rapid response and architectural resilience.

19 February 2026 | SGraph Send | Status: **RESOLVED**

EXECUTIVE SUMMARY	
----------------------------	--

On 19 February 2026, a critical credential leak was discovered in SGraph Send. Sender access tokens were exposed in shareable URL query strings. The issue was identified and patched in production within 100 minutes.	
--	--

International Orange	System Blue	Deep Charcoal
THE INCIDENT	THE SAFETY NET	THE FIX
Sender access tokens leaked in URL query parameters. Affected versions v0.1.3 through v0.1.6.	Zero-Knowledge Architecture meant zero file content was compromised. Attackers could authenticate, but never decrypt data.	8 files changed, token revocation recommended, and a new 'negative testing' suite implemented to verify sensitive data absence.

13:50: The Anomaly

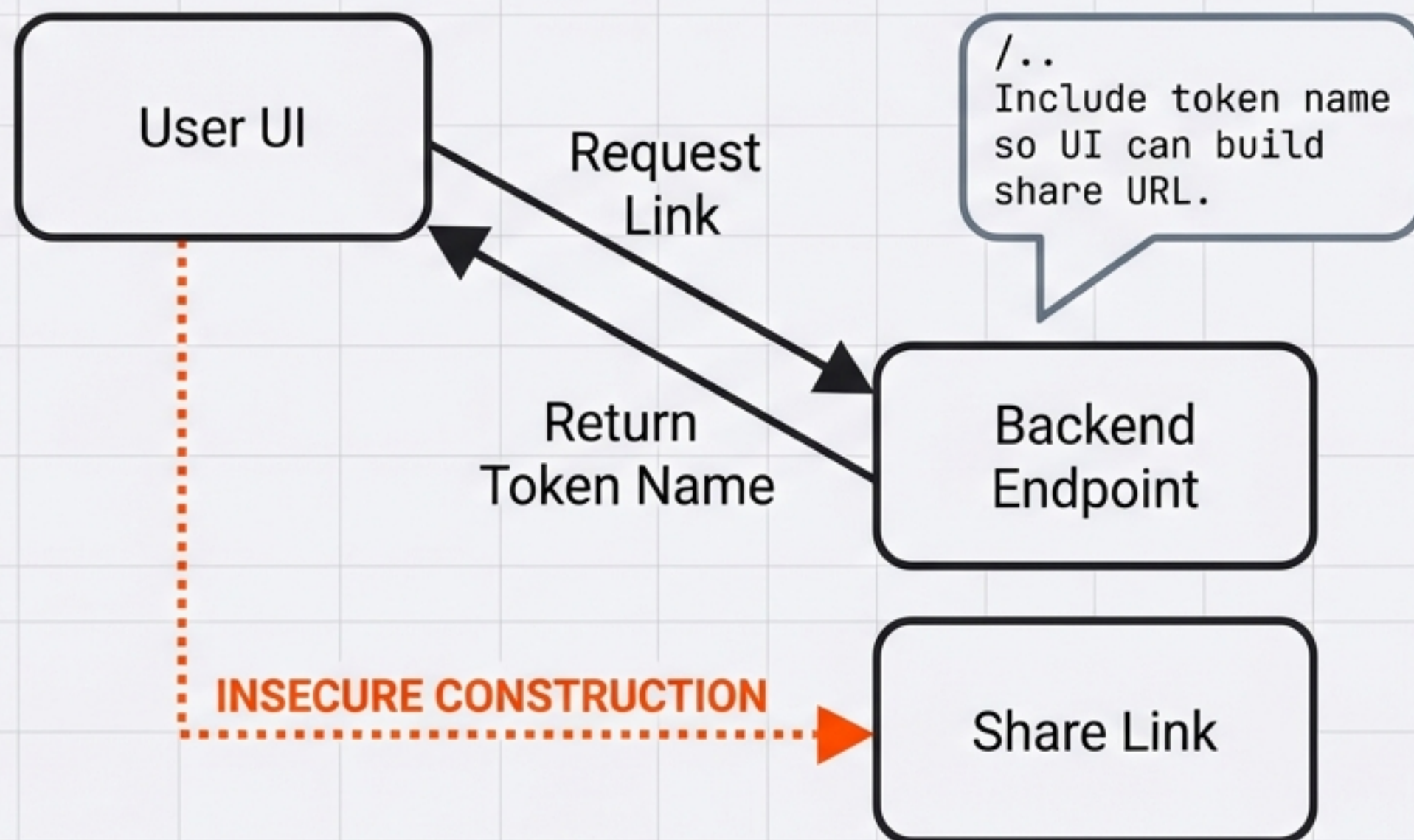
At 1:50 pm, while using SGraph Send to share a file, Dinis Cruz noticed a structural failure in the generated link.



This token was the sender's authentication key. Unlike the encryption key (safe in the hash fragment), this token sat in the query string—visible to servers, logs, proxies, and browser history.

Root Cause: A Shortcut in v0.1.3

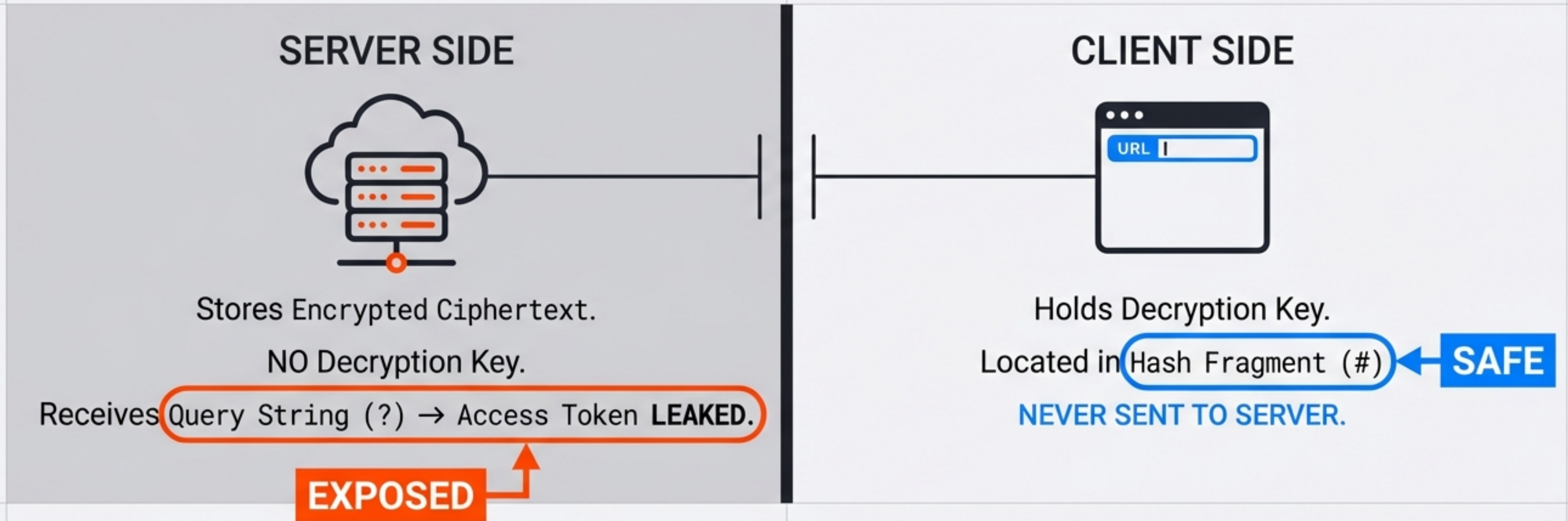
When download-side token validation was added in version 0.1.3, the implementation bypassed a separate authorisation mechanism. Instead, it forwarded the sender's token directly in the shareable URL.



The Blind Spot: Existing tests verified that URLs worked (positive testing), but no tests checked what the URLs contained (negative testing).

Why the Leak Didn't Compromise Data

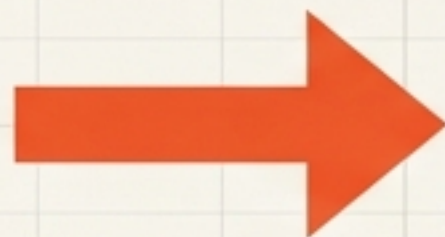
The protective power of Zero-Knowledge Architecture.



It doesn't matter what else leaks. The most sensitive data—the file content and the key to decrypt it—is **protected by architecture**, not by access control.

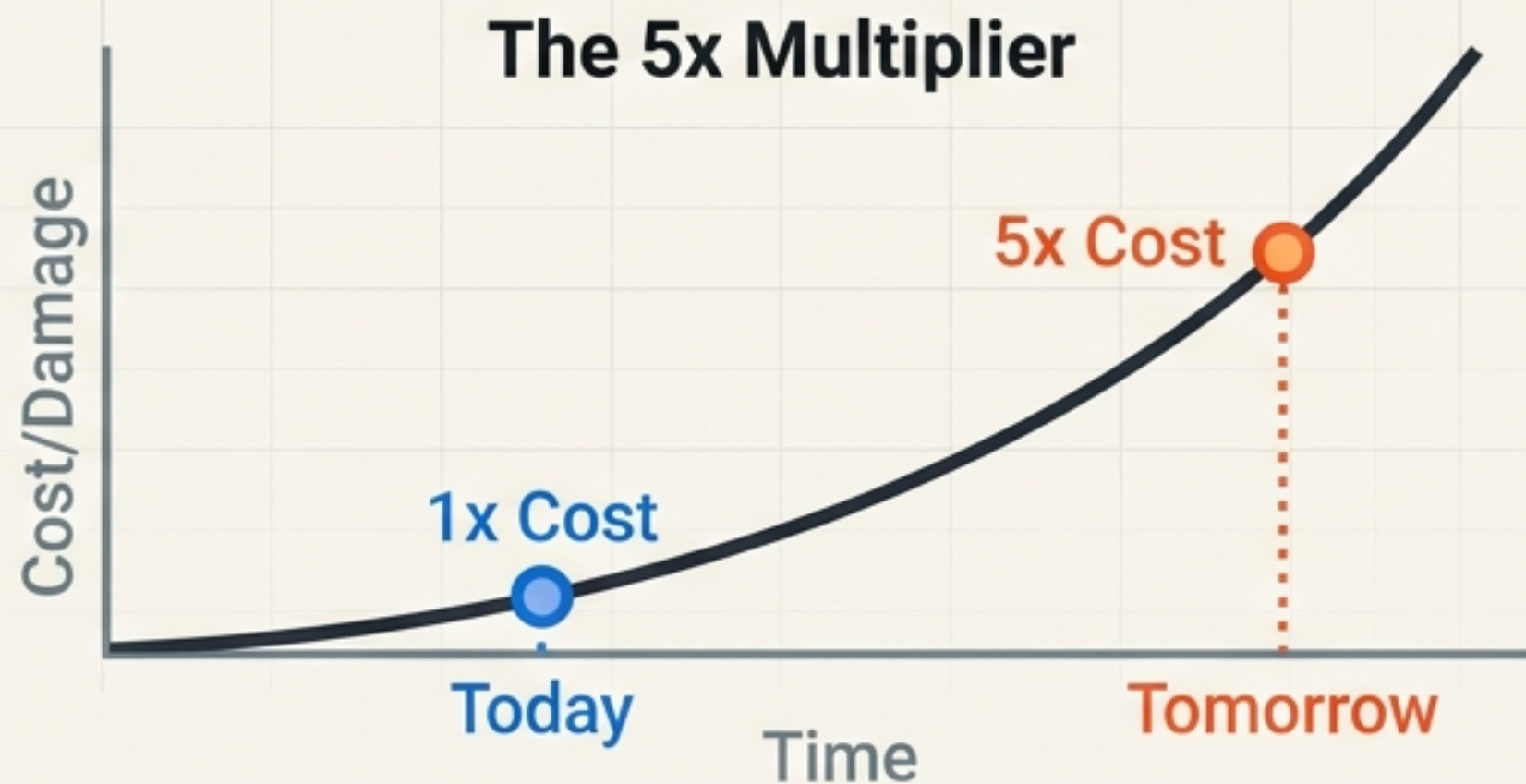
The P3-as-P1 Philosophy

P3
(Blast Radius)



P1 (Severity)

The incident was classified as **P3** by **blast radius (limited beta users)** but **P1** by **severity**. The token had been exposed since **v0.1.3**. **Every hour of delay** increased the **surface area** of compromised URLs in the wild. The **100-minute turnaround** wasn't **vanity**; it was **containment**.



Phase 1: Assessment (14:00 – 14:56)

14:00

Incident
Classified P1

14:56

AppSec Response
Report Produced

APPSEC RESPONSE REPORT

- Root cause identified.
- Affected versions mapped (v0.1.3 through v0.1.6).
- Token revocation strategy defined.
- Six preventive measures outlined.

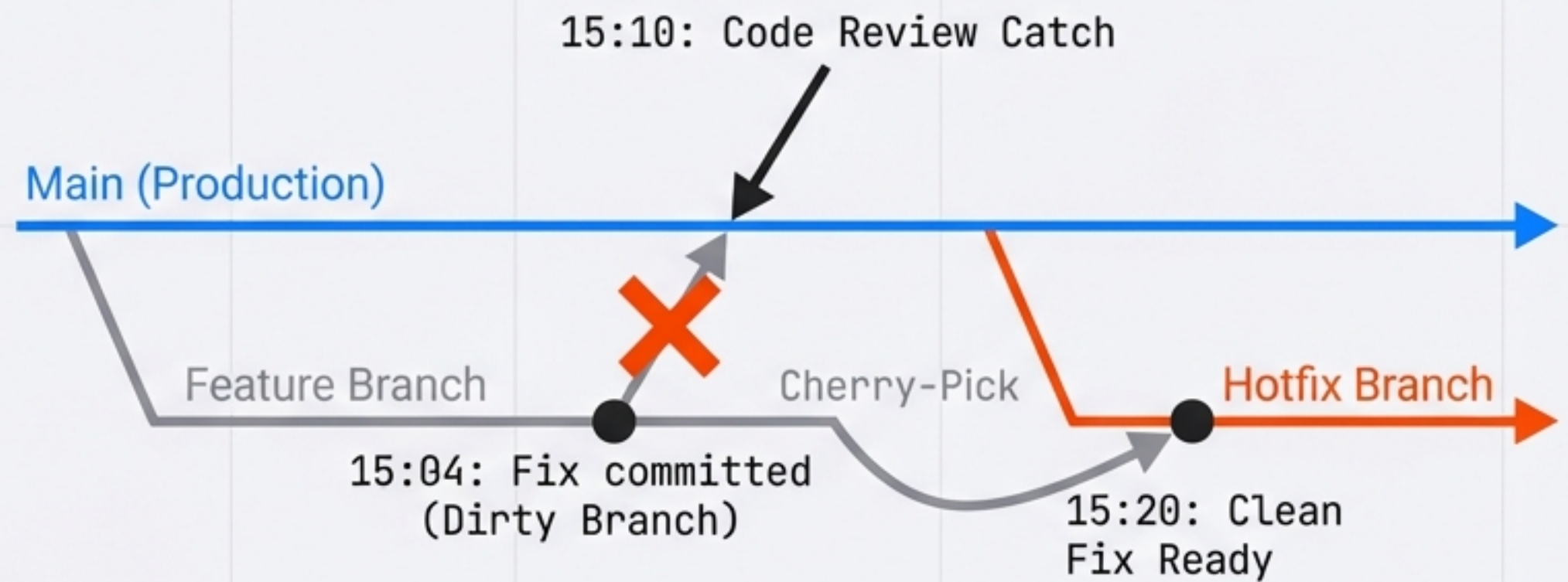
Phase 2: The Fix & Real-Time Process Correction

The Hiccup:

Code review caught the fix on a feature branch containing unreviewed work. Merging this would destabilise production.

The Correction:

Fix cherry-picked onto a clean hotfix branch. Process improvements happen during incidents.

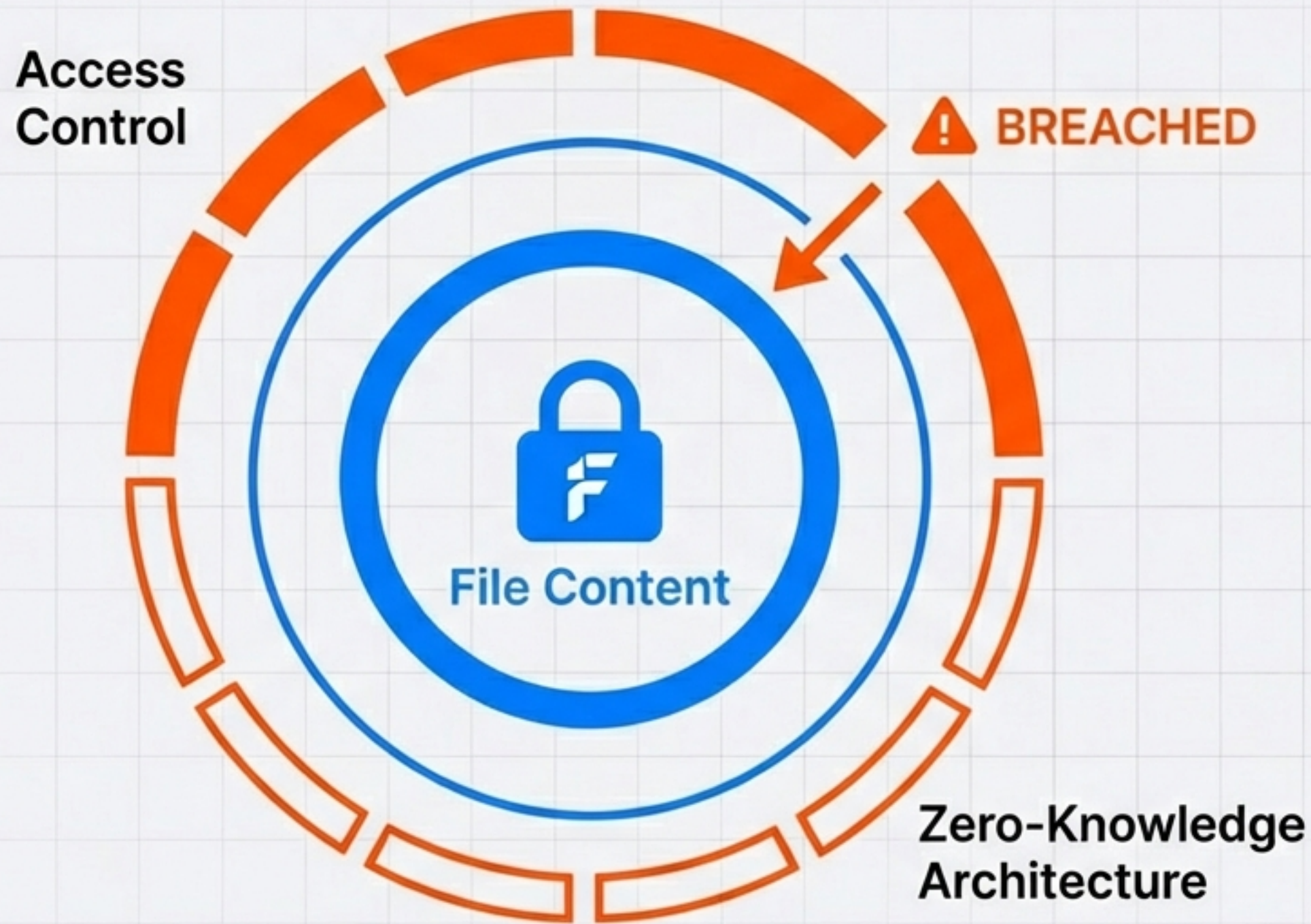


Phase 3: Deployment (15:30)



- ✓ **Status:** Live in Production.
- 🛡️ **Verification:** 153 tests passing (including new sanitisation suite).
- 🔒 **Result:** No query parameters. Nothing sensitive sent to the server.

Lesson 1: Architecture > Access Control



This was the second time in a week the Zero-Knowledge model proved its value. We cannot rely solely on keeping secrets. We must design systems that remain secure even when secrets leak.

Even with a real credential leak in production, the file content remained encrypted. The architecture contained the damage.

Lesson 2: The Power of Negative Testing

The Problem

Previous tests checked if URLs worked. Every test passed. No test checked what URLs contained.

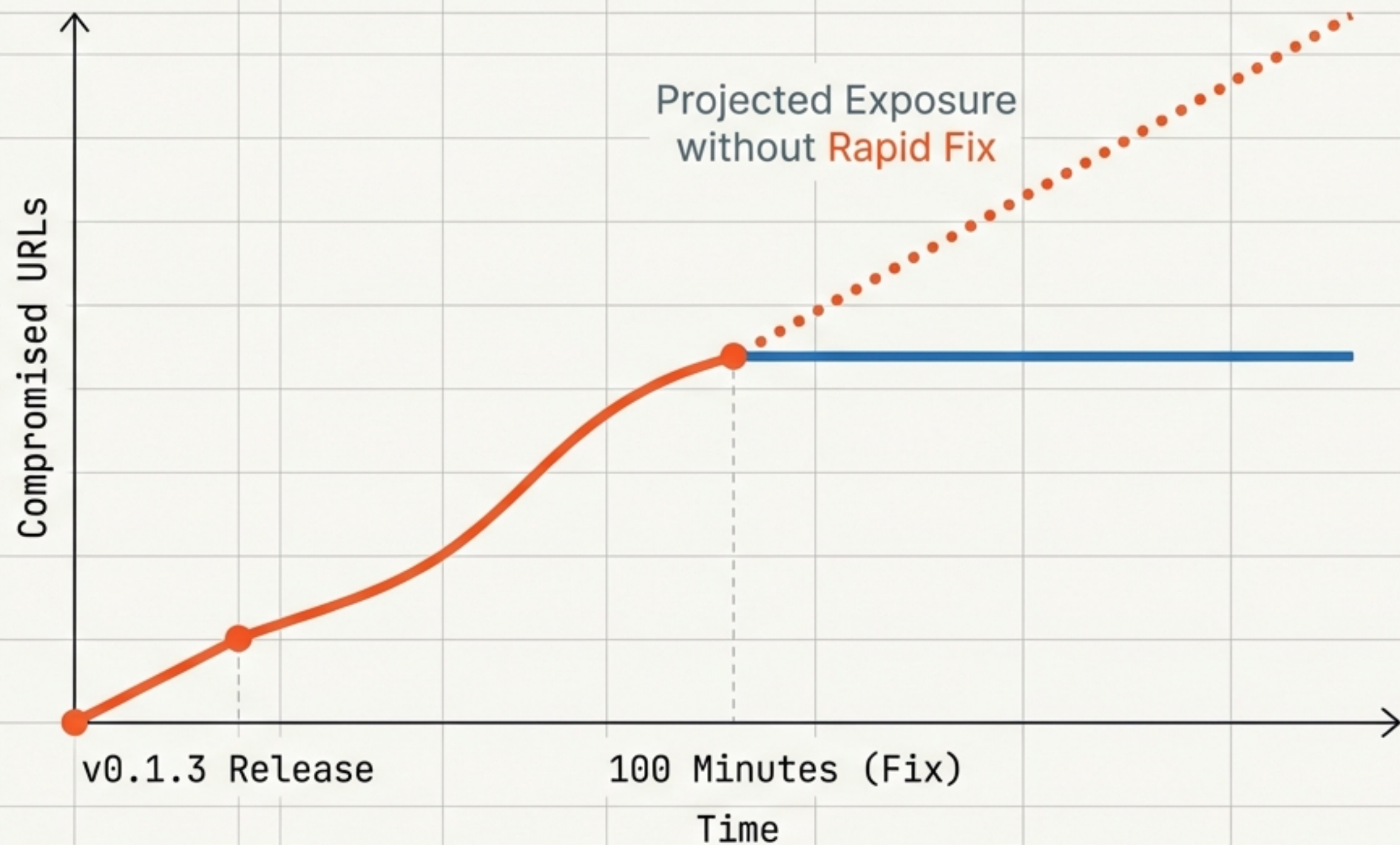
```
assert(url.contains(token) == False)  
assert(url.contains(password) == False)
```

The Solution

The hotfix introduced the project's first **negative security test suite**.

*“Don’t just test that the right things happen.
Test that the wrong things don’t.”*

Lesson 3: Speed is a Security Feature



In a credential leak, time is the enemy. The vulnerability existed for weeks.

Rapid remediation stops the bleeding.

A 100-minute fix drastically limited the number of new URLs generated with the vulnerability.

Incident INC-003 By The Numbers

**~100
Minutes**

Discovery to Fix

4

Versions Patched

8

Files Changed

1

New Test Suite

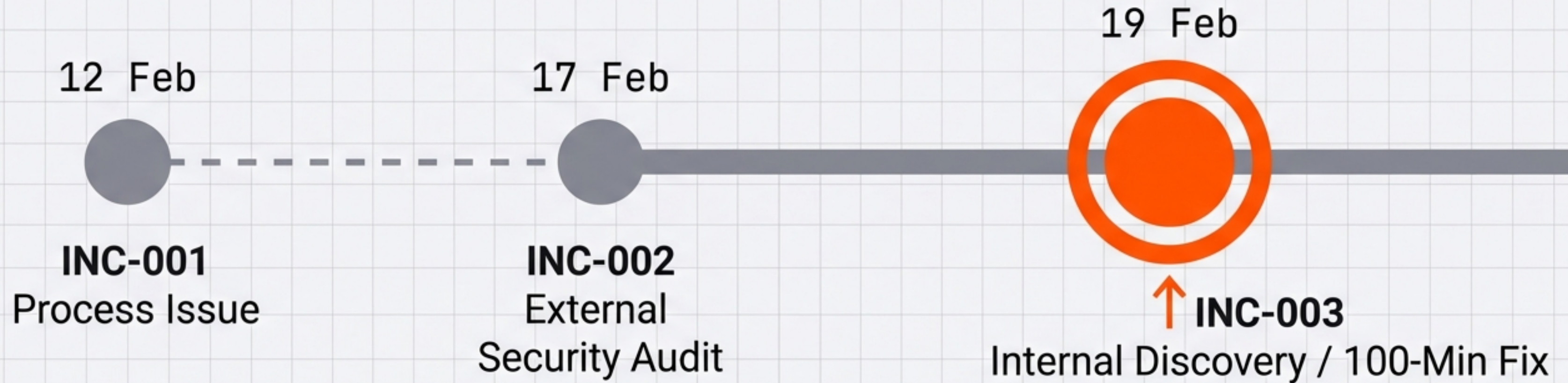
0

Encryption Keys Exposed

0

File Content Compromised

For The Record: Contextualising INC-003



The incident handling philosophy “Why We Treat Every Incident Like a Crisis” has now been battle-tested against process failure, external review, and internal discovery.

Final Status



Token leak fixed.



URLs sanitised.



Architecture validated.

Next Steps: Confirm token rotation status. Confirm server log audit completion.

The architecture held.